

09 Security

09.03 Firewall – 09.04 IPS and IDS

Firewall

- A firewall forms a barrier through which the traffic must pass.
- The security policy of the firewall dictates which traffic is authorized to pass in each direction.
- A firewall may be designed to operate as a filter at the network layer (for IP packets), or may operate at a higher layer for others protocols.
- The firewall is a line of defense, to insulate the internal systems from external networks

Firewall Characteristics

- **Service control:** Determines the types of Internet services that can be accessed, inbound or outbound.
- **Direction control:** Determines the direction in which particular service requests may be initiated and allowed to flow through the firewall.
- **User control:** Controls access to a service according to which user is attempting to access it.
- **Behavior control:** Controls how particular services are used

Firewall scopes

- A firewall defines a single choke point that keeps unauthorized users out of the protected network, prohibits potentially vulnerable services from entering or leaving the network, and provides protection from various kinds of IP spoofing and routing attacks.
- A firewall provides a location for monitoring security-related events. Audits and alarms can be implemented on the firewall system
- A firewall is a convenient platform for several Internet functions that are not security related.

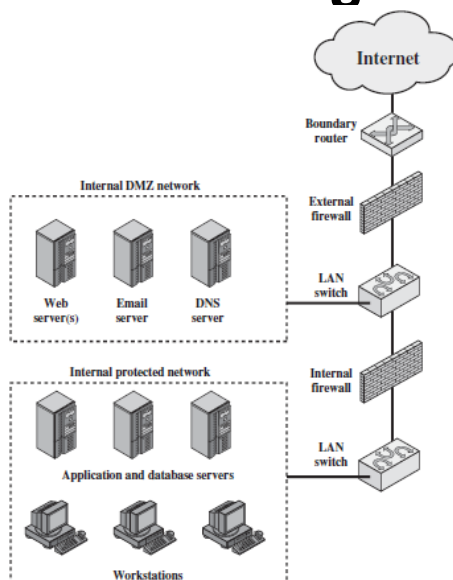
Firewall limitations

- The firewall cannot protect against attacks studied specifically to bypass the firewall. Internal systems may have dial-out capability to connect to an ISP.
- The firewall may not protect fully against internal threats, such as a disgruntled employee or an employee who unwittingly cooperates with an external attacker.
- An improperly secured wireless LAN may be accessed from outside the organization.

Firewall types

- **Packet Filtering Firewall:** they applies a set of rules to each incoming and outgoing IP packet and then forwards or discards the packet. The firewall is typically configured to filter packets going in both directions (from and to the internal network).
- **Stateful Inspection Firewall:** this type of firewall keeps track of the state of network connections (a TCP streams) traveling across it. The firewall is programmed to distinguish legitimate packets for different types of connections. Only packets matching a known active connection will be allowed by the firewall; others will be rejected.
- **Application-Level Gateway:** An application-level gateway, also called application proxy, acts as a relay of application-level traffic. The user contacts the gateway using a TCP/IP application, and the gateway asks the user for the name of the remote host to be accessed. When the user responds and provides a valid user ID and authentication information, the gateway contacts the application on the remote host and relays TCP segments containing the application data between the two endpoints
- **Circuit-Level Gateway:** This can be a stand-alone system or it can be a specialized function performed by an application-level gateway for certain applications. As with an application gateway, a circuit-level gateway does not permit an end-to-end TCP connection; rather, the gateway sets up two TCP connections, one between itself and a TCP user on an inner host and one between itself and a TCP user on an outside host.

Firewall Configuration



DMZ (Demilitarized Zone)

- A DMZ is a segment of a network or a network between the protected network and the Internet.
- The purpose of a DMZ is to provide some insulation and extra security to servers that provide the organization services for protocols such as HTTP/ SHTTP, FTP, DNS, and SMTP to the general public.
- One such setup is to make these servers:
 - Secure to access to them from the internal protected network.
 - Although there are restrictions on accesses from the outside network.

IDS and IPS

- The intrusion process into a system includes a number of stages:
 - Identification of the target.
 - Reconnaissance that produces as much information about the target as possible.
 - Gain access into the system.
 - (mis)Use of the resources of the system.

IDS and IPS

- Intrusion Detection is the art of detecting inappropriate, incorrect, or anomalous activity. Among other tools, an Intrusion Detection System can be used to determine if a computer network or server has experienced an unauthorized intrusion.
- An Intrusion prevention system is used to actively drop packets of data or disconnect connections that contain unauthorized data. Intrusion prevention technology can be also an extension of intrusion detection technology (IDS).

IDS

- The most important concept in the deployment of an IDS is that an IDS is a tool used to capture and provide visibility into a network.
- To have an IDS placed in the perimeter either between the border router and the firewall, it permits the defender to detect the attacker before he attempts to enter the firewalled zone.
- To install an IDS outside of the firewall and border router can permit to see the full breadth of attempted attacks against the network.

IDS pros and cons

- The IDS system is deployed in promiscuous mode meaning the sensor is placed where it can hear all the network traffic but is not in direct connect with the network
 - No network impact, latency, or jitters etc.
 - No network impact if there is a sensor failure
 - No network impact if there is a sensor overloaded.
- IDS does have some disadvantages compared to IPS
 - If packets trigger an alarm that's all it does is tell us that an attack is happening
 - Correct tuning is required for valid and invalid packets
 - The company must have a well thought-out security policy
 - Networks that are vulnerable must have evasion techniques

IDS pros and cons

- The IDS engine records the incidents that are logged by the IDS sensors in a database and generates the alerts it sends to the network administrator. Because IDS gives deep visibility into network activity, it can also be used to help pinpoint problems with an organization's security policy, document existing threats, and discourage users from violating an organization's security policy.
- The primary complaint with IDS is the number of false positives the technology is prone to spitting out – some legitimate traffic is inevitable tagged as bad

IPS disadvantages

- Like the IDS the IPS does have disadvantage when compared to IDS:
 - Since the sensor is connected directly (inline) with the network it might affect network traffic.
 - If the sensor is overloaded that will also impact the network.
 - A company must have a thought-out security policy.
 - There can be some latency, jitter etc. with the network.

Some Considerations

- Network attacks can happen fast and some of them only need a small amount of time to complete the attack, so once a network technician gets into the network equipment the attacker could be long gone and got what he/she needed.
- IPS is able to load signature files this is like the definitions on your anti-virus software which it looks for patterns based on the attack.
- Which IPS can take that same style and block those attacks based on the security policies you implement, along with alerting you of what happened.

Some Considerations

- In addition, an IPS can respond to a detected threat with reconfiguration of other security controls, such as a firewall or router, to block an attack
- Because IDS and IPS devices sit in different spots on the network, they can be used concurrently.
 - An IPS product installed at the perimeter of the network will help stop zero day attacks, such as worms and viruses, in their tracks – even the newest threats can be blocked with rigorous tuning.
 - An IDS product installed inside the firewall will monitor internal activity, guarding against the ever-present insider threat, and lend greater visibility into security events, past and present.